

Informe TLPT.

La TLPT, hija discípula de DORA y hermana del TIBER-EU, se está convirtiendo en un lenguaje común de “ciber-estrés test” a escala europea, y España ya juega en primera división con TIBER-ES y con los RTS conjuntos de las ESAs de 2024 como partitura oficial.¹²

1. Marco normativo TLPT 2025+ (España y mundo)

- DORA convierte la TLPT en prueba avanzada obligatoria para entidades financieras sistémicas y otras que superen umbrales cuantitativos, con aplicación desde enero de 2025 y frecuencia habitual trienal.³⁴¹
- El RTS conjunto de las ESAs de julio 2024 concreta criterios de selección, metodología, fases, requisitos de testers internos/externos, uso de inteligencia de amenazas y cooperación supervisora, constituyendo el estándar mínimo de TLPT bajo DORA.²¹³
- España adopta TIBER-EU mediante TIBER-ES (Guía de implementación 2022, Banco de España), manteniendo la lógica de tres fases (preparación, test, cierre), trabajo sobre entornos de producción y proveedores externos de TI y Red Team, ahora armonizable con DORA.²
- Varios países de la UE (NL, IE, DE, FR, IT, PT, SE, etc.) ya tenían marcos TIBER nacionales y los están alineando con los RTS TLPT, mientras que fuera de la UE predominan marcos equivalentes tipo CBEST (Reino Unido) o esquemas sectoriales basados en NIST/OSSTMM pero sin un RTS tan detallado.⁵¹²

Idea de mensaje para encuesta (tono irónico-constructivo):

- “Hemos pasado de jugar pachangas de pentest a la Champions League de la ciberresiliencia: ahora el reglamento viene numerado, firmado por las ESAs y con acta del TIBER-ES.”

2. Fases TLPT y familias de indicadores

2.1 Fase de preparación

Según TIBER-ES y los RTS DORA, la preparación incluye: constitución de White/Control Team, selección de proveedores, definición de alcance basado en funciones críticas, gestión de riesgos, planificación.³⁴

Familias de métricas:

1 <https://www.tarlogic.com/es/blog/pruebas-tlpt/>

2 <https://www.alter-solutions.es/pruebas-penetracion-amenazas-tlpt>

3 <https://itresit.es/dora-pruebas-tlpt/>

4 <https://www.alter-solutions.es/pruebas-penetracion-amenazas-tlpt>

- Alcance y criticidad
Porcentaje de funciones críticas de negocio cubiertas por el TLPT sobre el total de funciones críticas identificadas en el BIA.62
Número de servicios críticos soportados por terceros TIC incluidos en el test frente al total de servicios críticos externalizados.26
- Gobierno y madurez
Tiempo desde la notificación de obligación de TLPT por la autoridad hasta la designación formal del Control/White Team.12
Existencia de política formal de uso de testers internos (cuando se aplique DORA, con los requisitos específicos de política, recursos y mitigación de impacto sobre operaciones).1
- Proveedores y riesgo
Porcentaje de proveedores de TI/Red Team que cumplen los requisitos de experiencia, independencia, aseguramiento y cobertura de riesgos establecidos en el RTS y en las guías TIBER-EU de contratación.12
Número de riesgos identificados en el análisis de riesgo del TLPT y porcentaje con medidas de mitigación aceptadas antes del inicio del test.62
- Porcentaje de funciones críticas de negocio cubiertas por el TLPT sobre el total de funciones críticas identificadas en el BIA.62
- Número de servicios críticos soportados por terceros TIC incluidos en el test frente al total de servicios críticos externalizados.26
- Tiempo desde la notificación de obligación de TLPT por la autoridad hasta la designación formal del Control/White Team.12
- Existencia de política formal de uso de testers internos (cuando se aplique DORA, con los requisitos específicos de política, recursos y mitigación de impacto sobre operaciones).1
- Porcentaje de proveedores de TI/Red Team que cumplen los requisitos de experiencia, independencia, aseguramiento y cobertura de riesgos establecidos en el RTS y en las guías TIBER-EU de contratación.12
- Número de riesgos identificados en el análisis de riesgo del TLPT y porcentaje con medidas de mitigación aceptadas antes del inicio del test.62

2.2 Fase de test (Threat Intelligence + Red Team)

La metodología TLPT exige una fase de inteligencia dirigida (GTL/TTI) seguida de una campaña de Red Team activa de al menos 12 semanas sobre sistemas en producción.⁵⁶⁷

Familias de métricas:

- Inteligencia y escenarios
Número de escenarios de ataque definidos en el TTI alineados con el panorama de amenazas real del sector financiero español/europeo.⁶²
Porcentaje de escenarios TTI finalmente ejercitados por el Red Team en el plan de test.²⁶
- Ejecución Red Team
Duración real de la ventana de Red Team activo frente al mínimo regulatorio de 12 semanas.¹⁶
Número de “banderas” u objetivos críticos comprometidos (confidencialidad, integridad, disponibilidad, fraude, etc.) frente a los planificados en el alcance.⁶²
Número y tipo de ayudas concedidas por el White Team (bypasses de controles, accesos directos) y su impacto en la interpretación de resultados.⁶
- Detección y respuesta (Blue Team “a ciegas”)
Tiempo de detección del primer indicador de compromiso (MTTD TLPT) desde el inicio de actividades hostiles realistas por parte del Red Team.²⁶
Tiempo de contención (MTTC) y de recuperación (MTTR) de los sistemas o funciones afectados durante el ejercicio.⁶
Porcentaje de actividades del Red Team detectadas por los mecanismos de monitorización y el personal de operaciones (cobertura de detección).⁶
- Número de escenarios de ataque definidos en el TTI alineados con el panorama de amenazas real del sector financiero español/europeo.⁶²
- Porcentaje de escenarios TTI finalmente ejercitados por el Red Team en el plan de test.²⁶
- Duración real de la ventana de Red Team activo frente al mínimo regulatorio de 12 semanas.¹⁶
- Número de “banderas” u objetivos críticos comprometidos (confidencialidad, integridad, disponibilidad, fraude, etc.) frente a los planificados en el alcance.⁶²
- Número y tipo de ayudas concedidas por el White Team (bypasses de controles, accesos directos) y su impacto en la interpretación de resultados.⁶

5 <https://www.alter-solutions.es/pruebas-penetracion-amenazas-tlpt>

6 <https://itresit.es/dora-pruebas-tlpt/>

7 <https://www.tarlogic.com/es/blog/pruebas-tlpt/>

- Tiempo de detección del primer indicador de compromiso (MTTD TLPT) desde el inicio de actividades hostiles realistas por parte del Red Team.²⁶
- Tiempo de contención (MTTC) y de recuperación (MTTR) de los sistemas o funciones afectados durante el ejercicio.⁶
- Porcentaje de actividades del Red Team detectadas por los mecanismos de monitorización y el personal de operaciones (cobertura de detección).⁶

2.3 Fase de cierre, purple teaming y remediación

Los RTS hacen obligatoria la fase de purple teaming y replay en el cierre; TIBER-ES ya contemplaba informes detallados de Red Team y Blue Team, informe resumen y plan de acción.⁸⁹¹⁰

Familias de métricas:

- Calidad de informes
Plazo de entrega del Red Team Test Report y del Blue Team Test Report frente a los plazos de referencia del RTS (se ampliaron tras la consulta pública por preocupación de la industria).¹²
Grado de detalle técnico y de negocio en el Test Summary Report, medido por cobertura de todas las funciones críticas, TTP utilizadas y mapeo a controles.²¹
- Plan de remediación
Número total de hallazgos categorizados por criticidad (muy alto, alto, medio, bajo) y tipo (técnico, proceso, humano, tercero).¹²
Porcentaje de vulnerabilidades críticas y altas con plan de remediación aprobado en un máximo de 8 semanas tras el cierre (plazo de referencia indicado en prácticas DORA/TLPT).²¹
Porcentaje de acciones de remediación ejecutadas dentro del plazo comprometido, y número de hallazgos reabiertos en re-test posterior.⁶
- Cooperación supervisora
Tiempo desde la entrega del plan de remediación a la recepción de la “attestation” por parte de la autoridad TLPT, que certifica que el ejercicio se ha ejecutado conforme al RTS y que identifica funciones en alcance.¹

⁸ <https://www.tarlogic.com/es/blog/pruebas-tlpt/>

⁹ <https://www.alter-solutions.es/pruebas-penetracion-amenazas-tlpt>

¹⁰ <https://itresit.es/dora-pruebas-tlpt/>

- Plazo de entrega del Red Team Test Report y del Blue Team Test Report frente a los plazos de referencia del RTS (se ampliaron tras la consulta pública por preocupación de la industria).¹²
- Grado de detalle técnico y de negocio en el Test Summary Report, medido por cobertura de todas las funciones críticas, TTP utilizadas y mapeo a controles.²¹
- Número total de hallazgos categorizados por criticidad (muy alto, alto, medio, bajo) y tipo (técnico, proceso, humano, tercero).¹²
- Porcentaje de vulnerabilidades críticas y altas con plan de remediación aprobado en un máximo de 8 semanas tras el cierre (plazo de referencia indicado en prácticas DORA/TLPT).²¹
- Porcentaje de acciones de remediación ejecutadas dentro del plazo comprometido, y número de hallazgos reabiertos en re-test posterior.⁶
- Tiempo desde la entrega del plan de remediación a la recepción de la “attestation” por parte de la autoridad TLPT, que certifica que el ejercicio se ha ejecutado conforme al RTS y que identifica funciones en alcance.¹

Ejemplo de pregunta de encuesta (ad hoc, con un punto de mala leche):

- “Cuando le dijeron a su Blue Team que el ‘incidente’ había sido un TLPT, ¿la reacción mayoritaria fue: a) alivio, b) vergüenza profesional, c) petición de más presupuesto, d) todo lo anterior?”

3. Indicadores TLPT para uso nacional (España)

3.1 Indicadores a nivel de entidad

Pensados para ser agregables por supervisores (Banco de España, CNMV, DGSFP) bajo DORA y TIBER-ES.111213

¹¹ <https://www.alter-solutions.es/pruebas-penetracion-amenazas-tlpt>

¹² <https://www.tarlogic.com/es/blog/pruebas-tlpt/>

¹³ <https://itresit.es/dora-pruebas-tlpt/>

- Cobertura estructural
TLPT-01: Entidades obligadas que han realizado al menos un TLPT en el ciclo trienal vs. total de entidades identificadas según criterios RTS (G-SII, O-SII, infraestructuras de mercado, etc.).1
TLPT-02: Porcentaje de funciones críticas de negocio cubiertas por el TLPT más reciente.
- Calidad y rigor de prueba
TLPT-03: Porcentaje de TLPT con duración de Red Team ≥ 12 semanas y con uso efectivo de TTI alineado con GTL sectorial.261
TLPT-04: Porcentaje de TLPT con ejercicios de purple teaming completados y documentados.
- Eficacia de detección y respuesta
TLPT-05: MTTD mediano (en horas/días) frente a ataques TLPT exitosos, por tipo de técnica (credenciales, phishing, explotación de vulnerabilidad, cadena de suministro).6
TLPT-06: Porcentaje de ataques TLPT que alcanzan objetivos críticos sin detección previa.
- Gestión de vulnerabilidades
TLPT-07: Ratio hallazgos críticos/altos por TLPT y porcentaje cerrados en plazo $\leq 6/12$ meses.
TLPT-08: Porcentaje de hallazgos TLPT recurrentes (ya aparecían en el TLPT anterior o en un TIBER-ES previo).26
- TLPT-01: Entidades obligadas que han realizado al menos un TLPT en el ciclo trienal vs. total de entidades identificadas según criterios RTS (G-SII, O-SII, infraestructuras de mercado, etc.).1
- TLPT-02: Porcentaje de funciones críticas de negocio cubiertas por el TLPT más reciente.
- TLPT-03: Porcentaje de TLPT con duración de Red Team ≥ 12 semanas y con uso efectivo de TTI alineado con GTL sectorial.261
- TLPT-04: Porcentaje de TLPT con ejercicios de purple teaming completados y documentados.
- TLPT-05: MTTD mediano (en horas/días) frente a ataques TLPT exitosos, por tipo de técnica (credenciales, phishing, explotación de vulnerabilidad, cadena de suministro).6
- TLPT-06: Porcentaje de ataques TLPT que alcanzan objetivos críticos sin detección previa.
- TLPT-07: Ratio hallazgos críticos/altos por TLPT y porcentaje cerrados en plazo $\leq 6/12$ meses.
- TLPT-08: Porcentaje de hallazgos TLPT recurrentes (ya aparecían en el TLPT anterior o en un TIBER-ES previo).26

3.2 Indicadores agregados país/territorio

Orientados a cuadros de mando nacionales, alineados con DORA y con el rol del TIBER Cyber Team español.¹⁴¹⁵

- **Penetración TLPT**
% de activos financieros nacionales (por volumen de balance, transacciones, activos bajo gestión) cubiertos por al menos un TLPT en los últimos 3 años.
- **Madurez operativa**
Mediana de MTDD/MTTR TLPT a nivel de país, comparada con benchmarks europeos (cuando se publiquen análisis agregados).
- **Dependencias críticas**
Número de TLPT conjuntos o “pooled” que involucran proveedores TIC clave (cloud, core bancario, procesadores de pagos), indicando qué porcentaje del sector queda cubierto mediante estos ejercicios.¹
- % de activos financieros nacionales (por volumen de balance, transacciones, activos bajo gestión) cubiertos por al menos un TLPT en los últimos 3 años.
- Mediana de MTDD/MTTR TLPT a nivel de país, comparada con benchmarks europeos (cuando se publiquen análisis agregados).
- Número de TLPT conjuntos o “pooled” que involucran proveedores TIC clave (cloud, core bancario, procesadores de pagos), indicando qué porcentaje del sector queda cubierto mediante estos ejercicios.¹

¹⁴ <https://www.tarlogic.com/es/blog/pruebas-tlpt/>

¹⁵ <https://www.alter-solutions.es/pruebas-penetracion-amenazas-tlpt>

4. Comparativa internacional de indicadores TLPT

4.1 Europa (DORA + TIBER-EU)

- Estándar común
Los RTS de 2024 fijan requisitos homogéneos para criterios de selección, metodología, fases y cooperación supervisora, lo que permite comparar indicadores como frecuencia, cobertura, severidad de hallazgos y tiempos de remediación entre Estados miembros.³¹
- Caso España
España parte con ventaja al tener TIBER-ES operativo desde 2022; muchas métricas ya existen de facto (banderas, tiempos, cobertura) y solo requieren alineación terminológica con DORA.⁶²
- Los RTS de 2024 fijan requisitos homogéneos para criterios de selección, metodología, fases y cooperación supervisora, lo que permite comparar indicadores como frecuencia, cobertura, severidad de hallazgos y tiempos de remediación entre Estados miembros.³¹
- España parte con ventaja al tener TIBER-ES operativo desde 2022; muchas métricas ya existen de facto (banderas, tiempos, cobertura) y solo requieren alineación terminológica con DORA.⁶²

4.2 Reino Unido (CBEST) y otros

- Reino Unido
CBEST, precursor de TIBER-EU, ya utilizaba indicadores similares (éxito de escenarios, tiempo de detección, calidad de respuesta) en ejercicios orientados a infraestructuras críticas financieras; la convergencia con TLPT es alta, aunque el lenguaje normativo es distinto.
- Estados Unidos y otros
No cuentan con un RTS TLPT equivalente, pero se aproximan a través de marcos de “assumed breach”, red-teaming continuado y pruebas adversariales avanzadas ligadas a NIST CSF, con métricas de eficacia de controles, tiempos de contención y cobertura de monitoreo, que pueden mapearse a indicadores TLPT.
- CBEST, precursor de TIBER-EU, ya utilizaba indicadores similares (éxito de escenarios, tiempo de detección, calidad de respuesta) en ejercicios orientados a infraestructuras críticas financieras; la convergencia con TLPT es alta, aunque el lenguaje normativo es distinto.
- No cuentan con un RTS TLPT equivalente, pero se aproximan a través de marcos de “assumed breach”, red-teaming continuado y pruebas adversariales avanzadas ligadas a NIST CSF, con métricas de eficacia de controles, tiempos de contención y cobertura de monitoreo, que pueden mapearse a indicadores TLPT.

4.3 Tabla de ejes de comparación

Eje	España (TIBER-ES + DORA) 21	Resto UE (TIBER-EU + DORA) 13	UK (CBEST)	EEUU / otros
Naturaleza TLPT	Obligatoria para entidades designadas	Obligatoria para entidades designadas	Sectorial	Voluntaria/sectorial
Marco técnico	TIBER-ES alineado con TIBER-EU	TIBER-EU nacional	CBEST	NIST/proprios
Duración Red Team	≥ 12 semanas	≥ 12 semanas	Variable	Variable
Foco métricas	Función crítica, MTTR/MTTD, remediación	Idem, con variaciones locales	Escenarios, respuesta	Controles, tiempos
Supervisión y attestation	Attestation TLPT nacional	Attestation TLPT nacional/EMI	Regulador sectorial	Diverso

5. Líneas de evolución 2025-2027 en indicadores TLPT

- De “pasar el examen” a medir resiliencia real
El RTS deja claro que TLPT es un mínimo y que las autoridades pueden exigir ir más allá, lo que empujará métricas de madurez (ej. integración con Zero Trust, automatización de respuesta, calidad de telemetría) más allá del simple “conté los hallazgos”.²¹
- Más enfoque en terceros y pruebas conjuntas
Crecen las figuras de “pooled test” y “joint test” que obligan a definir indicadores sobre proveedores TIC compartidos (qué parte del riesgo sistémico se ha ejercitado realmente, cuántas funciones críticas de varios bancos dependen del mismo incidente simulado).¹
- Internalización controlada del Red Team
DORA permite testers internos con salvaguardas y exige externalizar al menos cada tercer test, lo que abre la puerta a indicadores de capacidad interna (número de pruebas adversariales internas al año, calidad de los informes, independencia) que complementen el TLPT regulatorio.¹
- El RTS deja claro que TLPT es un mínimo y que las autoridades pueden exigir ir más allá, lo que empujará métricas de madurez (ej. integración con Zero Trust, automatización de respuesta, calidad de telemetría) más allá del simple “conté los hallazgos”.²¹

- Crecen las figuras de “pooled test” y “joint test” que obligan a definir indicadores sobre proveedores TIC compartidos (qué parte del riesgo sistémico se ha ejercitado realmente, cuántas funciones críticas de varios bancos dependen del mismo incidente simulado).¹
- DORA permite testers internos con salvaguardas y exige externalizar al menos cada tercer test, lo que abre la puerta a indicadores de capacidad interna (número de pruebas adversariales internas al año, calidad de los informes, independencia) que complementen el TLPT regulatorio.¹

101112131415161718192021222324252627282930789